CLOUDGUARD

Detection, Monitoring &Response

The Frontline of Cloud Defense in 2026

CLOUD SIEM & LOGGING
THREAT DETECTION TOOLS
INCIDENT RESPONSE
CLOUD FORENSICS
ARCHITECTURE BLUEPRINTS
HANDS-ON LABS
SOAR & AUTOMATION

COMPILED & AUTHORED BY

Mohiuddin Sujan · Zahidul Islam Ratul · Al Mamun Siddique
Mahir Faysal · Aminul Islam

83%	276	81%	1hr
OF BREACHES START WITH IDENTITY ISSUES	AVG DAYS TO DETECT A BREACH	ORGS ON 2+ CLOUD PROVIDERS	ATTACKERS DEPLOY IN UNDER 1 HOUR

■ FROM THE EDITOR

Editor's Note

Mohiuddin Sujan — Editorial & Core Direction Lead

Welcome to **CloudGuard Magazine** — the publication born from a shared conviction that cloud security knowledge must be both technically rigorous and genuinely accessible. In this inaugural special edition, we tackle one of the most critical domains in modern cybersecurity: **Detection, Monitoring, and Response** in cloud environments.

The landscape has fundamentally shifted. Cloud infrastructure is no longer the future — it is the present. And yet, as our cover story makes viscerally clear, the cloud is on fire. Organizations are building faster than they are securing. Attackers move in seconds. Defenders scramble to keep up.

This edition brings together five perspectives — five authors, five specialties, one unified mission. Zahidul Islam Ratul dissects the industry briefing and documents the harrowing Operation SalesLoft supply chain attack. Al Mamun Siddique delivers a technical deep dive into detection architectures, governance frameworks, and the triad of cloud survival. Mahir Faysal and Aminul Islam equip you with hands-on lab walkthroughs using Wazuh, Wireshark, and Burp Suite — tools that transform theory into muscle memory.

> ❝ The cloud is not defended by products alone — it is defended by people who understand it deeply. This magazine is our contribution to that understanding.

Stay vigilant. Stay curious.

Mohiuddin Sujan

EDITOR-IN-CHIEF · CLOUDGUARD MAGAZINE · 2026

NAVIGATION

Table of Contents

00 **Editor's Note**
Awelcome from the editorial team — the conviction behind CloudGuard Magazine and this inaugural edition.
MOHIUDDIN SUJAN

01 **Industry Briefing**
Keytrendsshapingcloud security in 2026 — Zero Trust, AI Threats, Multi-Cloud & DevSecOps.
ZAHIDUL ISLAM RATUL

02 **Cover Story: The Cloud Is On Fire**
Identity attacks, misconfigurations, and AI-powered threats rewriting the rules of cloud defense.
ZAHIDUL ISLAM RATUL

03 **Technical Deep Dive**
Architecturalblueprints, detection engineering, SIEM pipelines, and IR at infrastructure speed.
AI MAMUN SIDDIQUE

04 **Cloud SIEM & Logging Architecture**
The Three-Tier Data Refinery—Bronze,Silver& Gold layers for unified visibility.
AI MAMUN SIDDIQUE

05 **Governance & Compliance**
CISBenchmarks,SOC 2,GDPR,FedRAMP and continuous compliance automation.
AI MAMUN SIDDIQUE

06 **Defense Lab — Hands-On Tutorials**
Wazuh brute force detection · Wiresharkpacket sniffing · Burp Suite web interception.
MAHIR FAYSAL

07 **Tools & Tech Radar**
Theessentialtoolkit— Wazuh, Wireshark, Burp Suite, AWS GuardDuty & more.
MAHIR FAYSAL

08 **Quick Bytes — Cheat Sheets**
Essential Linuxcommands,Wiresharkfilters, and Incident Response quick steps.
MAHIR FAYSAL

09 **Case File: Operation SalesLoft**
Anatomy of a supply chain attack —OAuth token abuse & the Fortune 500 breach cascade.
ZAHIDUL ISLAM RATUL

10 **Real-World Breach: Capital One 2019**
SSRF exploit, IAM credentialabuse,andthe 106M record lesson in misconfiguration.
AI MAMUN SIDDIQUE

11 **Cloud Security Learning Path**
Curatedcertifications,documentation, GitHub repositories, and YouTube tutorials for continuous growth.
MOHIUDDIN SUJAN

12 **The Cloud Defender's Mindset**
Threat modelling, thesix pillarsofsecurity thinking, and why mindset outperforms tooling in modern cloud defense.
MOHIUDDIN SUJAN

13 **The Human Factor in Cloud Security**
Culture, cognitiveoverload,insiderthreats, and building security-first engineering teams that truly learn.
MOHIUDDIN SUJAN

14 **The Human Side of Security**
Red Team vs BlueTeam, building your career, community resources, and practical steps to start your security journey today.
AMINUL ISLAM

SECTION 01 — INDUSTRY BRIEFING

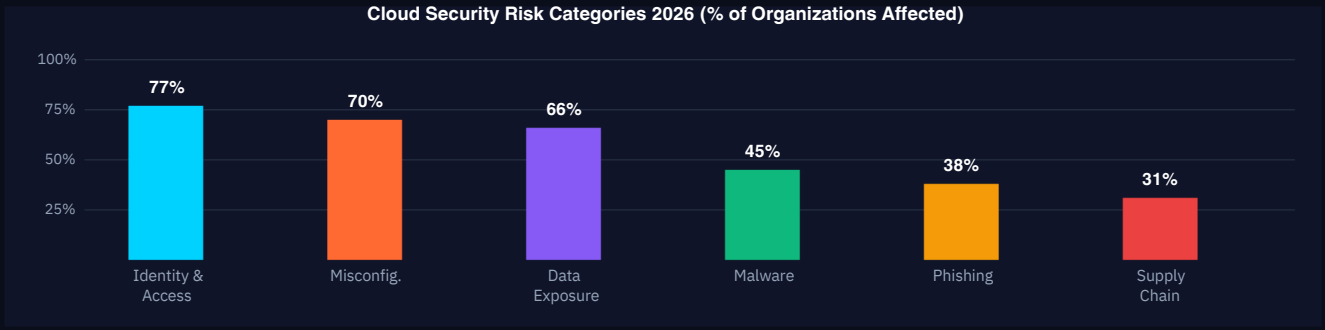
News & Trends: Cloud Security 2026

Written by Zahidul Islam Ratul — Industry & Feature Writer

The cloud security landscape in 2026 is defined by one uncomfortable truth: organizations are building faster than they are securing. As hybrid and multi-cloud adoption becomes the global norm, the attack surface expands at a pace that outstrips the human processes and fragmented tools used to defend it.

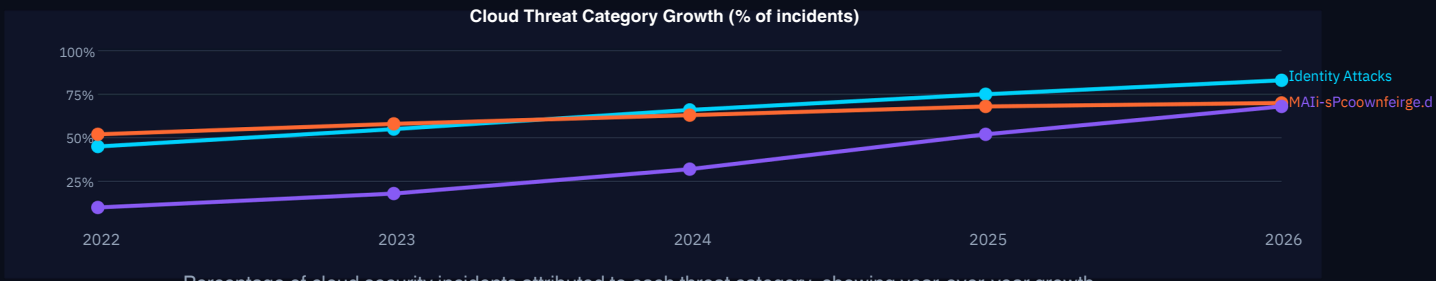
81%	77%	276	$377B
	IDENTITY & ACCESS TOP RISK	AVG DAYS TO DETECT A BREACH	

Cloud Security Risk Categories 2026



Source: Fortinet 2026 Cloud Security Report — percentage of organizations affected per risk category.

Threat Category Growth Trends (2022–2026)



Percentage of cloud security incidents attributed to each threat category, showing year-over-year growth.

TREND 01

Zero Trust Is Now the Default Architecture

The traditional 'trust but verify' model has been officially declared obsolete. In 2026, Zero Trust operates on one foundational principle: never trust, always verify. MFA, RBAC, microsegmentation, and identity-aware proxies are now standard enterprise components. Identity and access security tops the list of cloud-native risks at 77% — the perimeter is no longer a firewall; it is an identity.

TREND 02

AI-Powered Threat Detection Goes Mainstream

AI and machine learning are now central pillars of cloud threat detection. Platforms leverage real-time behavioral baselining to detect anomalies that traditional rule-based tools would miss. CSPM platforms embed AI to flag misconfigurations without manual review. Projected spending on AI-powered security solutions is expected to reach USD 377 billion by 2028.

TREND 03

Multi-Cloud Complexity Outpaces Defenses

81% of organizations rely on two or more cloud providers for critical workloads. This sprawl creates constant churn in assets, identities, and configuration states. Misconfigured cloud services account for 70% of reported risks, while data exposure sits at 66%. Multi-environment breaches take an average of 276 days to identify and contain — nearly nine months of undetected attacker presence.

TREND 04

DevSecOps Merges Security Into the Pipeline

The 'shift-left' movement has matured. DevSecOps in 2026 means security teams are embedded directly into development workflows from the first line of code. Automated code scanning, container security checks, and IaC validation catch vulnerabilities before they reach production. Organizations that have adopted the model see threat visibility improvements exceeding 40%.

■ SECTION 02 — COVER STORY

The Cloud Is On Fire

How Identity Attacks, Misconfigurations & AI-Powered Threats Are Rewriting the Rules · By Zahidul Islam Ratul

> ❝ "Somewhere in a cloud workload right now, an attacker is moving laterally through an organization's infrastructure using nothing more than a stolen OAuth token and a misconfigured IAM policy. No zero-day exploit. No sophisticated malware. Just trust — abused."

THE IDENTITY CRISIS AT THE HEART OF CLOUD SECURITY

If there is one theme that unites the cloud security narrative of 2026, it is the catastrophic failure of identity governance. According to Google Cloud's Threat Horizons Report for H1 2026, threat actors exploited identity issues to gain initial access in **83% of incidents** involving major cloud and SaaS environments. Eight in ten breaches started not with a firewall bypass or a vulnerability exploit — they started with an identity problem.

Machine identities — API keys, service accounts, automation credentials, and OAuth tokens — now dramatically outnumber human identities in most enterprise environments. Gartner warns that these non-human identities are frequently unmanaged, ungoverned, and invisible to security teams. When an attacker compromises a single service account with overly permissive IAM policies, they gain the keys to the kingdom.

MISCONFIGURATIONS: THE OPEN DOOR NOBODY NOTICES

The 2026 cloud threat environment is littered with misconfigured S3 buckets, over-permissive security groups, publicly exposed APIs, and storage containers with no encryption at rest. Google Cloud's security engineers observed threat actors exploiting misconfigured applications and deploying cryptomining payloads in Google Kubernetes Engine instances within **under one hour** of resource creation.

AI AS BOTH SHIELD AND SWORD

The AI revolution has arrived in cybersecurity — on both sides of the battlefield. AI-powered SOAR platforms reduce mean time to respond from hours to minutes. But attackers are equally equipped. 68% of threat analysts report that AI-generated phishing attempts are now harder to detect than ever. Voice cloning technologies require only 3–5 seconds of audio to produce convincing impersonations of executives.

> ■ The cloud has not been breached because defenders lacked technology. It has been breached because defenders **misunderstood the battlefield**.

■ SECTION 03 — TECHNICAL DEEP DIVE

The Triad of Cloud Survival

By Al Mamun Siddique — Technical Deep Dive Specialist

In the 2026 threat landscape, effective Detection, Monitoring, and Response requires shifting from static perimeter defense to a dynamic, identity-centric architecture. Below, we break down the four pillars of cloud threat detection.

■ Signature-Based Detection

Uses fingerprints of known historical attacks. Effective for well-documented threats but often crumbles under the sheer volume of modern cloud telemetry. Best paired with behavioral analytics.

■ Behavior-Based Detection (UEBA)

Leverages User and Entity Behavior Analytics to baseline normal activity. Identifies anomalies such as a service account logging in from a Tor exit node, or impossible travel between distant locations within minutes.

■ Detection Engineering (DaC)

Detection-as-Code treats security rules like production software. Rules are written in SQL/Python/Sigma, stored in Git, and deployed via CI/CD pipelines. Every rule must pass unit tests, replay tests, and negative tests.

■ Threat Intelligence Integration

Ingesting feeds via STIX/TAXII standards allows systems to automatically correlate internal logs with known malicious indicators — IP reputation, C2 server lists, domain age, and more — in real time.

WHAT DO THESE TERMS ACTUALLY MEAN?

01

Monitoring

Continuous data gathering— a security camera recording every walk-in and exit in your cloud environment. VPC Flow Logs, CloudTrail, Activity Logs.

02

Detection

The alarm system.Analyzes monitoring data to find suspicious patterns — logins from restricted countries, unusual API calls, abnormal data access volumes.

03

Incident Response

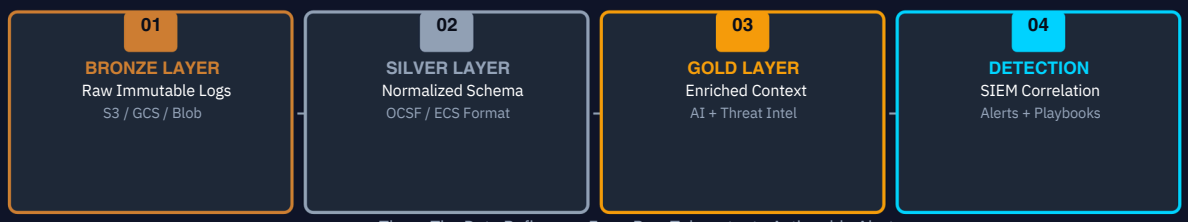
The fire drill. Organizedapproach to containing the threat, removing the attacker, and fixing the damage. Follows the NIST IR Framework.

■ SECTION 04 — ARCHITECTURE BLUEPRINT

Cloud SIEM & The Three-Tier Data Refinery

By Al Mamun Siddique — Technical Deep Dive Specialist

A robust logging architecture is the foundation of forensic readiness and real-time detection. The Three-Tier Data Refinery eliminates provider-specific technical debt by normalizing heterogeneous logs from AWS, Azure, and GCP into a unified schema.



Three-Tier Data Refinery — From Raw Telemetry to Actionable Alerts

LAYER	NAME	PROCESS & STANDARDS	TECHNICAL DESCRIPTION
01 Data Sources	Multi-Cloud Telemetry	Raw Ingestion	AWS CloudTrail, Azure Activity Logs, GCP Audit Logs, K8s Audit Logs, VPC Flow Logs, IdP (Okta/Entra ID)
02 Bronze Layer	Immutable Audit Trail	Zero Modification	Raw logs stored in S3, GCS, or Blob Storage. Immutable for forensic reprocessing.
03 Silver Layer	Normalized Schema	OCSF / ECS	Maps diverse provider fields to a common language, reducing engineering query effort from 3x to 1x.
04 Gold Layer	Enriched Context	AI + Threat Intel	Augments logs with PII tags, asset sensitivity, IP reputation. Reduces false positives by up to 90%.

SIEM Detection Pipeline — How the Brain Works

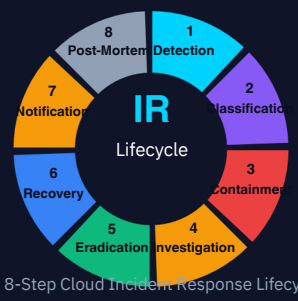
STAGE	STEP	TECHNICAL ACTION	OBJECTIVE
01	Raw Event Log Ingestion	Collecting raw data	CloudTrail, VPC Flow Logs, Azure Activity Logs
02	Preprocessing	Schema Normalization	Converting to structured OCSF/ECS format for portable detection rules
03	Detection Logic	Signature + Behavioral	Matching against known threats or behavioral anomalies
04	Decision Branch	Binary Alert/Ignore	TRUE → SOAR alert fired; FALSE → event archived for audit

SOC Monitoring Workflow — Alert to Resolution

STEP	STAGE	TECHNICAL ACTION	OUTCOME
01	SIEM Alert	Alert Fired	High-fidelity notification based on correlated log events
02	Tier 1 Triage	Benign or Malicious?	Filter false positives; escalate genuine threats

STEP	STAGE	TECHNICAL ACTION	OUTCOME
03	Tier 2 Deep Hunt	Context Enrichment	Smart Timelines, UEBA cross-reference, blast radius assessment
04	Resolution	Close the Loop	Upgraded to P0 Incident or closed with documented finding

Incident Response Lifecycle — Visual Overview



8-Step Cloud Incident Response Lifecycle

IR at Infrastructure Speed — SOAR & Automation

CloudIncident Response must operateat infrastructurespeed using SOAR— Security Orchestration, Automation, and Response. The moment a threat is confirmed, automated playbooks must act within seconds, not hours.

PHASE	STAGE	KEY TECHNICAL ACTIONS	EXPECTED OUTCOME
01	Detection	Confirm Breach (P0 Alert)	Validating the threat; triggering Priority 0 incident
02	Classification	Severity & Scope Assessment	Determine blast radius, affected assets, data sensitivity
03	Containment	Isolate VM / Suspend IAM ID	Stop lateral movement; revoke compromised credentials instantly
04	Investigation	Cloud Forensics & Log Analysis	Audit trail reconstruction; root cause identification
05	Eradication	Remove Root Cause	Delete backdoors, patch vulnerabilities, reset credentials
06	Recovery	Restore from Secure Backups	Clean snapshot deployment; IaC-based infrastructure rebuild
07	Notification	Regulatory & Stakeholder Alerts	GDPR 72-hour notice, legal counsel, customer communication
08	Post-Mortem	Lessons Learned	Update policies, detection rules, playbooks, training

■ Google Cloud security engineers observed threat actors exploiting misconfigured applications and deploying cryptomining payloads within **under one hour** of resource creation. Manual IR processes cannot compete. SOAR is not optional — it is the minimum viable defense posture.

■ SECTION 05 — GOVERNANCE & COMPLIANCE

Continuous Compliance in the Cloud Era

By Al Mamun Siddique — Technical Deep Dive Specialist

Compliance is evolving from annual point-in-time audits to continuous automated assurance. In a cloud environment where resources appear and disappear in minutes, governance must operate at the speed of infrastructure.

CISBENCHMARKS

- ✓ Prescriptive security configurations for AWS, Azure, GCP
- ✓ Implementation reduces misconfigured resources by up to 81.67%
- ✓ Automated via tools like Prowler, AWS Config, Security Hub
- ✓ Continuously monitored — not just checked at audit time
- ✓ Covers IAM policies, network controls, logging requirements

SOC 2 / ISO 27001

- ✓ CloudTrail and Config provide immutable evidence for auditors
- ✓ Automated evidence collection via Akitra, Sprinto, Vanta
- ✓ Continuous control monitoring vs. annual snapshot audits
- ✓ Trust Service Criteria mapped to cloud security controls
- ✓ Real-time compliance dashboards for security posture

FedRAMP & DoD

- ✓ Impact Levels: IL2, IL4, IL5, IL6 for data sensitivity
- ✓ FedRAMP Authorization required for Federal cloud deployments
- ✓ Continuous monitoring obligations — monthly scans minimum
- ✓ NIST 800-53 controls baseline for all federal systems
- ✓ FISMA compliance required for all federal agency use

ZERO TRUST & BEST PRACTICES

- ✓ Least Privilege: Only minimum permissions; Just-in-Time access
- ✓ Encryption at rest and in transit; keys managed separately
- ✓ Zero Trust: 'Never trust, always verify' every request
- ✓ Centralize logs to a SIEM for 24/7 visibility
- ✓ Shift-Left: Security checks in CI/CD pipelines

CLOUD SECURITY BEST PRACTICES — THE 10 COMMANDMENTS

01

Least Privilege Access

Grantonly minimumrequiredpermissions. Use Just-in-Time access models for privileged operations.

02

Encrypt Everything

Securedataat restandin transit. Maintain encryption keys separately from the data they protect.

03

Zero Trust Model

Every request verified based on identity, device posture, and context — regardless of network location.

04

Centralize Logs

Route alltelemetryto a central SIEM for 24/7 visibility. No blind spots. No isolated log silos.

05

Automate Compliance

Replace manualaudits withcontinuous automated compliance checks using IaC security scanning.

06

Multi-Factor Auth

Enforce MFAon all privileged accounts. Consider FIDO2/passkeys for phishing-resistant authentication.

SECTION 06 — DEFENSE LAB

Hands-On Security Tutorials

By Mahir Faysal — Hands-On & Tools Specialist

Theory is nothing without practice. These three labs simulate real-world defense scenarios using industry-standard tools. Each lab builds core skills directly applicable to cloud security operations.

LAB 01 Wazuh — Detecting a Brute Force Attack

Objective: Detect an SSH brute force password attack on a Linux cloud server using Wazuh SIEM.

SETUP: Linux VM + Wazuh Agent → Wazuh Manager Dashboard

- Attempt to SSH into your server with a wrong password multiple times to simulate an attack
- Open terminal and run: `ssh fakeuser@your-server-ip`
- Log into the Wazuh Dashboard and navigate to Security Events
- Filter for Rule ID 5712 — 'SSHD brute force trying to get access'
- Check the 'Top 5 Alerting Rules' pie chart for spikes in Authentication Failures

```
Alert: SSHD brute force trying to get access
Level: 10 | Rule ID: 5712
Source IP: 192.168.1.50 | Agent: cloud-server-01
Attempts: 47 failed logins in 3 minutes
```

✓ What you learned: Detecting credential stuffing attacks in real time via SIEM correlation rules.

LAB 02 Wireshark — Intercepting Cleartext Credentials

Objective: Analyze unencrypted HTTP traffic to find a stolen password in transit.
SETUP: Wireshark installed locally + sample HTTP .pcap capture file

- Open Wireshark and load your HTTP traffic capture file (.pcap)
- In the filter bar, type the display filter: `http.request.method == "POST"`
- Right-click the result and select **Follow → TCP Stream**
- Look for the text user= and pass= in plain text

```
POST /login.php ...
log=admin&pwd;=Password123&wp-submit;=Log+In
```

✓ What you learned: Why HTTPS is non-negotiable. Any plaintext credential is a stolen credential.

LAB 03 Burp Suite — Intercepting & Modifying Web Requests

Objective: Intercept and modify a web request to understand how attackers manipulate data sent to cloud servers.
SETUP: Burp Suite Community Edition + built-in Burp Browser

- Open Burp Suite → navigate to the **Proxy** tab → enable **Intercept is ON**
- In the Burp Browser, navigate to a test site (e.g., testphp.vulnweb.com)
- Submit any form — the browser will freeze as Burp catches the outgoing request
- In the intercepted request, modify the User-Agent header: `User-Agent: HackerBot/1.0`
- Click **Forward** — observe that the server responds to your modified request
- Use **Repeater** tab to replay modified requests and observe security flaws

✓ What you learned: How attackers manipulate HTTP requests before they reach cloud servers — the basis of web application attacks.

■ SECTION 07 — TOOLS & TECH RADAR

The Cloud Defender's Essential Toolkit

By Mahir Faysal — Hands-On & Tools Specialist

The right tools transform reactive security into proactive defense. Below is the CloudGuard-curated Tech Radar for Detection, Monitoring & Response in cloud environments.

TOOL	CATEGORY	PURPOSE & KEY CAPABILITIES	BEST FOR
Wazuh	EDR / SIEM	Open-source SIEM + EDR platform. File integrity monitoring, threat detection, compliance (PCI DSS, GDPR), vulnerability assessment, incident response.	Monitoring cloud servers for brute force, unauthorized file changes, insider threats
Wireshark	Network Analysis	Deep packet inspection and protocol analysis. Captures and dissects network traffic in real time. Industry-standard forensic investigation tool.	Network forensics, detecting malware C2 communication, finding cleartext credentials
Burp Suite	Web App Security	Intercepting proxy for web application testing. Identifies OWASP Top 10 vulnerabilities including SQL injection, XSS, SSRF, and insecure deserialization.	Testing cloud-hosted web applications for exploitable vulnerabilities before attackers do
AWS GuardDuty	Managed Threat Detection	Native AWS intelligent threat detection service. Analyzes CloudTrail, VPC Flow Logs, DNS logs. Detects Bitcoin mining, hijacked accounts, data exfiltration.	AWS environments needing zero-configuration threat detection with ML-powered analysis
Microsoft Sentinel	Cloud SIEM / SOAR	Cloud-native SIEM + SOAR on Azure. 200+ data connectors, built-in ML detection, automated response playbooks via Logic Apps.	Enterprise Azure environments requiring unified security operations and automated response
Splunk	SIEM / Analytics	Industry-leading log aggregation, search, and correlation. Powerful SPL query language. Thousands of apps and integrations for any data source.	Large enterprises needing flexible, powerful log analysis and custom detection engineering
Prowler	CSPM / Audit	Open-source cloud security tool for AWS, Azure, GCP. 300+ checks across CIS Benchmarks, GDPR, HIPAA, SOC 2. CLI and dashboard output.	Automated cloud security posture assessment and continuous compliance auditing
CrowdStrike Falcon	EDR / XDR	AI-powered endpoint detection and response. Cloud-native architecture with threat graph. Threat hunting, malware analysis, real-time blocking.	Cloud workload protection, container security, and cross-environment XDR correlation

■ SECTION 08 — QUICK BYTES

Cybersecurity Cheat Sheet & Command Reference

By Mahir Faysal — Hands-On & Tools Specialist

Cut straight to the commands that matter. These cheat sheets are your rapid-reference during investigations, lab sessions, and real incident response scenarios.

ESSENTIAL LINUX COMMANDS

`tail -f /var/log/auth.log`
Watch login attempts in real-time

`netstat -tulpn`
See all active network connections & ports

`last`
See who recently logged into the system

`psaux | grep  suspicious`
Find suspicious running processes

`ss -tulpn`
Modern socket statistics (replaces netstat)

`find / -mtime -1-typef`
Files modified in the last 24 hours

WIRESHARK FILTERS

`ip.addr == 10.0.0.1`
Show traffic for a specific IP

`dns`
Show all DNS website lookups

`tcp.flags.syn==1 && tcp.flags.ack==0`
Find potential port scans

`http.request.method == "POST"`
Capture POST requests (login data)

`ssl.handshake.type == 1`
Find TLS Client Hello packets

`!(arp or dns or icmp)`
Remove noise, show real traffic only

INCIDENT RESPONSE STEPS

STEP 1: VERIFY
Confirm the alert is a real attack, not a false positive

STEP 2:ISOLATE
Disconnect the affected VM from the internet immediately

STEP 3:SNAPSHOT
Take a disk image/snapshot for digital forensic evidence

STEP 4:REMEDIATE
Change all passwords, rotate API keys, revoke tokens

STEP 5: DOCUMENT
Record timeline, actions taken, and lessons learned

STEP 6: IMPROVE
Update detection rules to prevent recurrence

AWS CLOUD SECURITY QUICK COMMANDS

AWS CLI — SECURITY AUDIT	GUARDDUTY ALERT TYPES	WAZUH RULE IDs

`aws cloudtrail lookup-events --lookup-attributes AttributeKey=EventName, AttributeValue=ConsoleLogin`
`aws s3api get-bucket-acl --bucket BUCKET_NAME`
`aws iam get-account-password-policy`
	Exfiltration:S3/AnomalousBehavior
	CryptoCurrency:EC2/BitcoinTool.B
	UnauthorizedAccess:IAMUser/InstanceCredentialExfiltration
		Rule 5712 — SSHD brute force
		Rule 5503 — PAM: User login failed
		Rule 5402 — Successful sudo to root
		Rule 550 — Integrity checksum changed

■ SECTION 09 — CASE FILE: REAL INCIDENT

Operation SalesLoft

When Supply Chain Trust Becomes a Weapon · By Zahidul Islam Ratul

■ CLASSIFIED INCIDENT — SUMMER 2025 | Threat Actor: UNC6395 (linked to ShinyHunters / Scattered Spider) · Target: Supply Chain Trust

4.46M	6M+	100s	F500

Attack Chain Progression

Operation SalesLoft —AttackChainProgression (Summer 2025)

Recon & Target	OAuth Theft	Lateral Move	Exfiltration	Cascade
PHASE 1	PHASE 2	PHASE 3	PHASE 4	PHASE 5
SalesLoft platform identified	Token ecosystem compromised	Salesforce envs accessed silently	4.46M+ records stolen	100s of orgs breached

PHASE 1 — THE SETUP

Threat actor group UNC6395 targeted SalesLoft — a widely adopted sales engagement platform deeply integrated with Salesforce deployments across hundreds of enterprise clients. Rather than attacking SalesLoft's core infrastructure directly, attackers focused on the OAuth token ecosystem connecting SalesLoft to its customers' Salesforce environments. OAuth tokens are the digital handshakes that allow integrated SaaS applications to communicate seamlessly — and when stolen, they provide attacker-controlled access that appears entirely legitimate to every monitoring system watching.

PHASE 2 — THE ATTACK CHAIN

Attackers leveraged the stolen OAuth tokens to move laterally through connected Salesforce environments. Each compromised token granted access to that organization's entire Salesforce database — customer records, business contracts, financial data, and enterprise communications. The attack was silent: it used legitimate authentication pathways, bypassing traditional anomaly detection rules configured for credential stuffing or brute force.

PHASE 3 — THE VICTIMS

Google confirmed a breach of its Salesforce-hosted corporate database in August 2025. TransUnion disclosed the exposure of personal data belonging to 4.46 million US consumers. Workday, Farmers Insurance, Chanel, and Qantas were among the dozens of major organizations caught in the same attack. Qantas, already managing a separate contact-center breach exposing six million customers, faced compounding regulatory pressure from multiple simultaneous disclosure requirements.

THE LESSONS LEARNED

The common thread across all victims: they were all connected to SalesLoft through Salesforce OAuth integrations, and none had sufficient visibility into that integration's behavior to detect the breach before significant damage had occurred. The attack exposed a fundamental gap in third-party integration monitoring.

■ STRATEGIC TAKEAWAY: The supply chain is now the front line. Every SaaS integration creates a trust relationship, and every trust relationship is a potential attack path. Implement OAuth token usage monitoring, set behavioral baselines for all third-party integrations, and audit privileged integration scopes quarterly.

■ SECTION 10 — REAL-WORLD BREACH ANALYSIS

Capital One 2019: The IAM Misconfiguration That Cost 106 Million Records

By Al Mamun Siddique — Technical Deep Dive Specialist

■ FORENSIC CASE STUDY — 2019 | Attack Vector: SSRF → Metadata Service → IAM Role Abuse → S3 Mass Exfiltration

The Attack

An attacker used Server-Side Request Forgery (SSRF) to exploit a misconfigured Web Application Firewall (WAF). The misconfigured WAF allowed the attacker to make outbound requests to the AWS metadata service at 169.254.169.254, retrieving temporary IAM credentials for an over-privileged IAM role.

The Impact

106 million customer records were exposed after the attacker used the stolen IAM credentials to synchronize contents from over 700 S3 buckets. Personal information including names, addresses, credit scores, and Social Security numbers was exfiltrated in one of the largest financial data breaches in history.

The Detection Failure

The breach persisted for months before detection because the API calls used legitimate IAM credentials — the same signals that normal operations generate. Without behavioral baselines for S3 access patterns and UEBA on IAM role usage, the exfiltration was invisible against normal operational noise.

The Lesson

Robust security requires: (1) Regular WAF configuration audits; (2) Strict privilege separation — no single IAM role should have access to hundreds of S3 buckets; (3) IMDSv2 enforcement to block SSRF metadata exploitation; (4) GuardDuty enabled to detect anomalous S3 access patterns.

THE FUTURE OF CLOUD SECURITY DETECTION

EMERGING

Generative AI in Security Operations

ToolslikeMicrosoft Security Copilotand SentinelOne Purple AI provide contextual incident summaries, guide analyst investigations, and suggest remediation steps — dramatically reducing time-to-response for Tier 1 and Tier 2 analysts.

EMERGING

Identity Orchestration & Dynamic Trust

StaticIAM roles will bereplacedby dynamic, real-time trust signals that continuously evaluate identity risk based on device posture, behavioral context, threat intelligence, and environmental signals — adjusting access in real time.

EMERGING

Converged Security Platforms

Security and compliance will mergeinto unified cloud-native platforms providing real-time trust scores to customers. Manual compliance checklists will be fully replaced by continuous automated assurance with audit-ready evidence generated automatically.

EMERGING

Autonomous Defense Systems

Agentic AI will move beyond SOAR playbooks to fully autonomous security — identifying drift, triggering remediation, hunting threats, and patching vulnerabilities without human intervention. The SOC of 2028 will look radically different.

■ SECTION 11 — LEARNING RESOURCES

Your Cloud Security Learning Path

Curated by Mohiuddin Sujan & the CloudGuard Team

OFFICIAL DOCUMENTATION

- ✓ Wazuh Documentation — Complete SIEM/EDR setup guide
- ✓ Wireshark User Guide — Packet analysis from beginner to expert
- ✓ Burp Suite Academy — Free web security training
- ✓ AWS CloudTrail Docs — Logging & event history
- ✓ AWS GuardDuty Developer Guide
- ✓ Microsoft Sentinel Documentation
- ✓ Google Cloud Security Best Practices

GITHUB REPOSITORIES

- ✓ Awesome-Cloud-Security — Massive curated tool list
- ✓ Cloud-Security-Suite — Auditing for AWS/GCP/Azure
- ✓ Wazuh Ruleset — How detection rules are written
- ✓ Detection-Lab — Pre-configured security lab in minutes
- ✓ Prowler — Best open-source AWS/Azure security tool
- ✓ Sigma Rules — Universal detection rule format
- ✓ MITRE ATT&CK; Cloud Matrix — Adversary technique library

CERTIFICATIONS & COURSES

- ✓ SANS SEC541 — Cloud Threat Detection
- ✓ SANS SEC510 — Cloud Security Engineering
- ✓ AWS Security Specialty Certification
- ✓ Azure Security Engineer Associate (AZ-500)
- ✓ Google Professional Cloud Security Engineer
- ✓ ISC2 CCSP — Certified Cloud Security Professional
- ✓ CompTIA Security+ with Cloud Track

YOUTUBE & PODCASTS

- ✓ NetworkChuck: Wireshark is EASY IppSec:
- ✓ HackTheBox Walkthroughs Leron Gray: Wazuh
- ✓ Setup Guide SANS Institute: Incident Response
- ✓ Webcasts John Hammond: Malware Analysis
- ✓ Basics Cloud Security Podcast (weekly
- ✓ episodes) David Bombal: Network Security
- ✓ Fundamentals

> ❝ "Modern cloud security is not a bolt-on afterthought — it is a continuous, automated discipline. Success depends on standardizing logs, enforcing Zero Trust, and leveraging SOAR to respond at infrastructure speed."

SECTION 12 — SECURITY MINDSET

The Cloud Defender's Mindset

By Mohiuddin Sujan — Editorial & Core Direction Lead

Security is not a product you purchase — it is a discipline you practice. In an era where cloud environments spin up in seconds and attackers operate faster than any alert queue can process, the most critical asset a defender possesses is not their SIEM or their SOAR platform. It is their mindset.

THE ATTACKER THINKS IN SYSTEMS. SO MUST YOU.

The most dangerous adversaries do not target individual vulnerabilities — they exploit the relationships between systems. A misconfigured IAM policy is dangerous. A misconfigured IAM policy connected to an over-permissive service account that has write access to a production S3 bucket containing customer PII is catastrophic. Understanding how components interact — how trust flows, how data moves, how credentials propagate — is the difference between a defender who patches and a defender who protects.

ASSUME BREACH

Do not design systems on the assumption they will never be compromised. Design them on the assumption they already are. Ask: if an attacker is already inside, what can they reach? What would stop them?

THINK LIKE AN AUDITOR

Before an attacker finds your gaps, find them yourself. Regularly review IAM policies, check public-facing assets, audit third-party integrations. The most dangerous misconfigurations are the ones nobody remembers creating.

AUTOMATE THE MUNDANE

Human attention is finite and precious. Every task that can be automated — log aggregation, compliance checking, credential rotation, patch scanning — should be automated. Reserve human judgment for the decisions that genuinely require it.

DOCUMENT EVERYTHING

During an incident, the team with documentation wins. Runbooks, network diagrams, IAM inventories, incident timelines — these are not bureaucratic overhead. They are the difference between a four-hour recovery and a four-week crisis.

BUILD FOR FAILURE

Cloud infrastructure is ephemeral. Assume components will fail, credentials will be rotated, regions will go down. Architect for resilience: immutable infrastructure, automated recovery, clean backups tested regularly in isolation.

SECURITY IS EVERYONE'S JOB

The era of the security team as the sole guardian of the perimeter is over. Developers write IAM policies. DevOps teams manage secrets. Product managers set data retention rules. Security culture must be embedded across every function — not outsourced to a single team.

THE THREAT MODEL IS YOUR NORTH STAR

Every cloud deployment should begin with a threat model. Who are your adversaries? What do they want? What assets are you protecting? What are your trust boundaries? A threat model does not need to be a 50-page document — even a one-page diagram showing data flows, trust zones, and high-value assets forces the conversations that prevent the most common catastrophic failures.

STEP	ACTION	DESCRIPTION
01	Identify Assets	List every data store, API endpoint, service account, and secret. You cannot protect what you have not inventoried.

STEP	ACTION	DESCRIPTION
02	Define Trust Boundaries	Draw lines between internal services, third-party integrations, public interfaces, and privileged systems. Each line is a potential attack path.
03	Enumerate Threats	Use STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege) to systematically identify threats at each trust boundary.
04	Assess & Prioritize	Not every threat is equal. Score threats by likelihood and impact. Focus engineering effort on the scenarios most likely to cause real damage.
05	Define Mitigations	For each high-priority threat, define a specific technical or procedural control. Assign ownership. Set a timeline. Track completion.
06	Review Continuously	A threat model is not a one-time exercise. Every new feature, every new integration, every new team member changes the model. Build review into your development lifecycle.

> ❝ Security is not a destination — it is a continuous process of understanding, adapting, and improving. The defenders who win are not those with the most tools, but those who think most clearly about the problem.

■ SECTION 13 — THE HUMAN FACTOR

The Human Factor in Cloud Security

By Mohiuddin Sujan — Editorial & Core Direction Lead

Across every major cloud breach documented in this edition — from the Capital One SSRF exploit to Operation SalesLoft — a consistent truth emerges: the technology did not fail first. A human decision created the condition that made the breach possible. A developer provisioned an over-permissive IAM role. An engineer left a WAF misconfigured. An administrator approved a third-party OAuth scope without reviewing its blast radius. The cloud is only as secure as the human judgment that shapes it.

WHY HUMANS REMAIN THE CRITICAL VARIABLE

Modern cloud platforms offer every control needed to build a genuinely secure environment. AWS, Azure, and GCP all provide robust IAM, encryption, logging, and anomaly detection. The gap between available controls and deployed controls is almost always a human gap — a gap in awareness, in process, in culture, or in time. Closing that gap is the hardest problem in cloud security because it cannot be solved by purchasing a product.

COGNITIVE OVERLOAD

The average cloud security team monitors hundreds of services, thousands of IAM entities, and millions of log events per day. No human can process this volume without automation. Alert fatigue is not a character flaw — it is a predictable consequence of undersized teams defending oversized environments. The solution is not to hire faster — it is to automate ruthlessly so that human attention is reserved for genuinely novel decisions.

SECURITY CULTURE vs. SECURITY COMPLIANCE

Compliance frameworks tell you what controls to check. Culture determines whether those controls are actually followed when no auditor is watching. Organizations with strong security cultures share incident post-mortems openly, reward the engineer who raises a security concern over the one who ships fastest, and treat security as a shared responsibility rather than a tax imposed by a separate team. Culture cannot be mandated — it must be modelled from leadership.

THE INSIDER THREAT REALITY

Not all threats arrive from the outside. Disgruntled employees, compromised contractor accounts, and well-intentioned engineers with excessive permissions all represent insider risk vectors. The principle of least privilege is not a compliance checkbox — it is the most practical defence against insider threats. Regular access reviews, JIT (Just-in-Time) provisioning, and separation of duties are the operational controls that make this real.

KNOWLEDGE GAPS IN FAST-MOVING TEAMS

Cloud platforms release hundreds of new features and services every year. The team that deployed your Kubernetes cluster in 2023 may not be aware of the security implications of the new networking features released in 2025. Continuous learning — through internal knowledge-sharing, certifications, threat intelligence briefings, and publications like this one — is not optional. It is the only way to keep pace with the environment you are defending.

BUILDING A SECURITY-FIRST CULTURE: PRACTICAL STEPS

01

Run Blameless Post-Mortems

When incidents occur — and they will — the response must focus on system improvement, not individual blame. Teams that fear punishment hide incidents. Teams that conduct blameless post-mortems learn from them. Document what happened, why, what could have prevented it, and what will change. Publish findings internally.

02

Security Champions Programme

Embed a security-aware engineer in every product team. This person does not need to be a security expert — they need to be the bridge between the security team and the development team. They raise security considerations in sprint planning, flag suspicious dependencies, and escalate unusual access requests.

03

Gamify Security Training

Annual security awareness videos do not change behaviour. Capture-the-flag competitions, phishing simulations with immediate coaching, bug bounty programmes, and tabletop incident exercises create muscle memory. Make security training challenging, relevant, and consequential.

04

Measure What Matters

Track mean time to detect, mean time to respond, percentage of IAM roles reviewed quarterly, percentage of secrets rotated on schedule, and number of critical misconfigurations remediated within SLA. What gets measured gets managed. Publish these metrics to leadership — security becomes a priority when it has numbers attached to it.

> ❝ Technology solves technical problems. Culture solves human problems. The most resilient cloud security programmes invest in both — and they understand that one cannot compensate for the absence of the other.

■ SECTION 14 — THE HUMAN SIDE OF SECURITY

The Human Side of Security

By Aminul Islam — Hands-On & Tools Specialist

Security is not just about computers and code. It is about **people**. You can have the best tools in the world, but if the person using them doesn't know what to do, the system will fail. Let's talk about how you can start your journey.

1. Red Team vs. Blue Team: Which One Are You?

In the security world, we usually have two sides. It's like a game of hide and seek.

■ RED TEAM

The Hackers

These people try to break things. They look for holes in the system. If you love solving puzzles and finding secrets, you will love being on the Red Team. You will use tools like **Burp Suite** to find weak spots.

■ BLUE TEAM

The Guards

These people protect the system. They watch the walls and stop the bad guys. If you like helping people and being a hero, the Blue Team is for you. You will use **Wazuh** to see if anyone is trying to break in.

■ **The Secret:** The best security professionals know a little bit of both! Red and Blue skills together make you a **Purple Teamer** — the most versatile defender in the field.

2. How to Build Your Career (Simple Steps)

You don't need to learn everything in one day. Just follow this path:

01

Learn the Basics

First, learn how the internet works. Learn how to use a computer with just your keyboard (Linux). Understanding networking fundamentals — IP addresses, DNS, HTTP/S, TCP/UDP — gives you the foundation everything else builds on.

02

Pick a Cloud

Choose one platform: AWS, Azure, or Google Cloud. Learn how they keep data safe — IAM roles, storage permissions, VPCs, and logging. Focus on one before trying to master all three.

03

Build a Lab

This is the most important part. Set up Wazuh on your own laptop. Try to attack your own system and see if you can catch yourself. Hands-on practice is worth more than any certification alone.

04

Talk to People

Don't be shy. Go to LinkedIn and share what you are learning. Write short posts about the labs you ran, the errors you made, and what you figured out. The security community notices people who show their work.

3. The Community Is Your Friend

Youarenotalone.Therearethousandsofpeopledoingthesame thing. Lean on the community — it accelerates everything.

GitHub
This is like a social network for coders. Post your lab work here. It shows people that you actually know how to do the work — not just theory.

YouTube
Watch channels like **Simply Cyber**. They explain things in a very easy way for beginners. Visual learning accelerates understanding of complex topics.

Medium
Read stories from other people who started just like you. Real experience posts from practitioners beat documentation every time.

Ask Questions
If you get stuck, ask! The security community loves to help. No question is too basic. Every expert was once a beginner who asked the same question.

Where to Learn? (Easy Links)

For News Follow **Google Cloud Security Blog**. It's the official news — straight from the source, no noise.

For Labs Look for **Cybersecurity Roadmaps** on GitHub. Hands-on guided paths that take you from zero to practical skills.

For Fun Listen to **Darknet Diaries**. It's like listening to a scary storybook about hackers — real incidents told as gripping narratives.

Final Tip: Don't worry about being perfect. Just start today. Even if you only learn one new command, that is a win! Every expert in this field started exactly where you are right now.

"The cloud is not a destination — it is a battlefield. Know your terrain, watch your gates, and never stop learning."

COMING NEXT ISSUE

Identity & Access Management in the Cloud

Zero Trust IAM · Privileged Access · Non-Human Identities · OAuth Security

THE CLOUDGUARD TEAM

MS	ZR	AM	MF	AI
Mohiuddin Sujan	Zahidul Islam Ratul	Al Mamun Siddique	Mahir Faysal	Aminul Islam

CLOUDGUARD